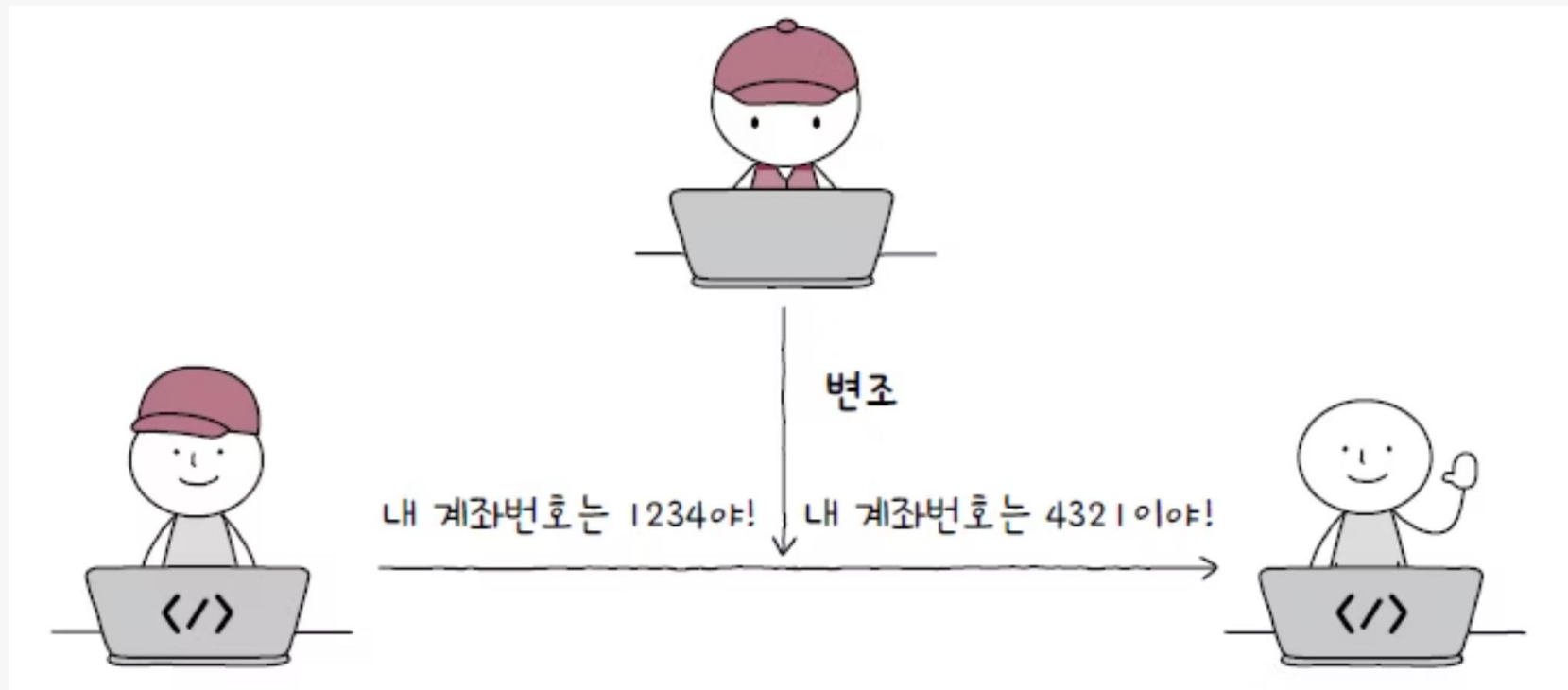


안전성을 위한 기술

- 안전한 통신을 위해 사용 가능한 네트워크 기술

안전성을 위한 기술 (1)

- 암호화(encryption)
 - 원문 데이터를 알아볼 수 없는 형태로 변경
- 복호화(decryption)
 - 암호화된 데이터를 원문 데이터로 되돌리는 과정
- 암호화와 복호화는 안전한 데이터 송수신뿐만 아니라 인증서 기반의 검증도 가능하게 함

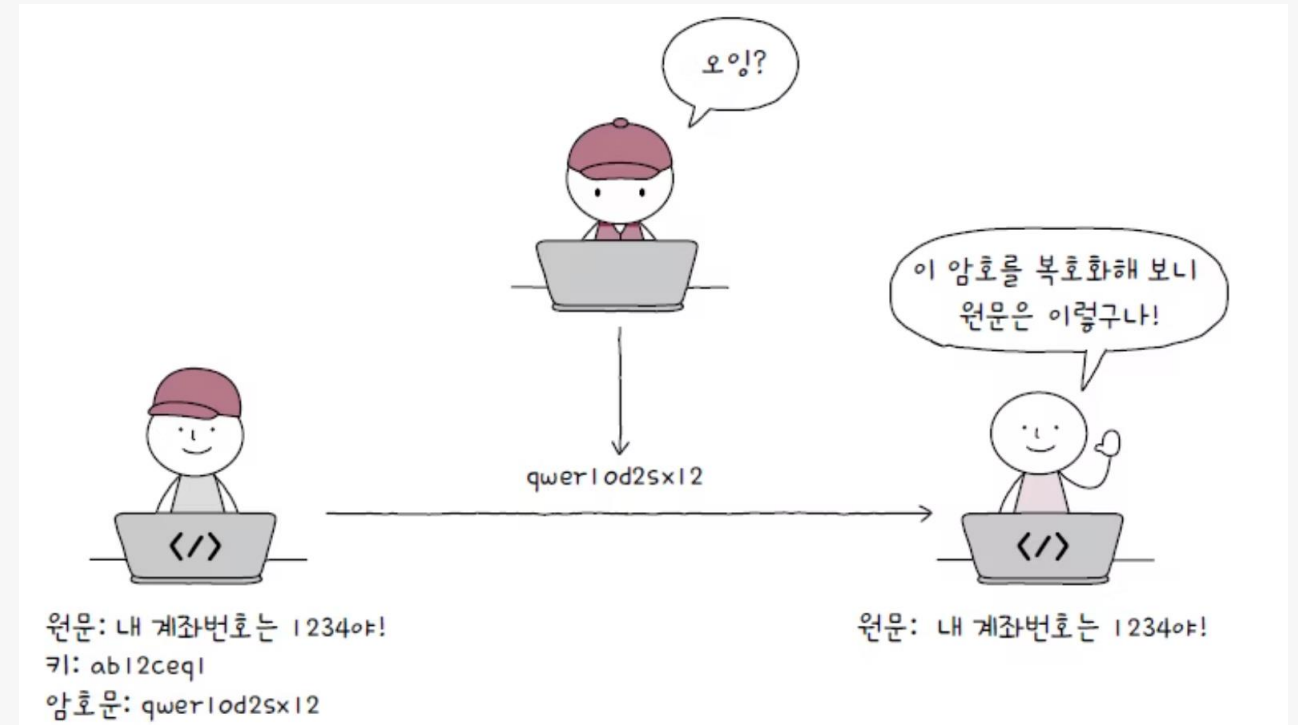


안전성을 위한 기술(2)

암호와 인증서

대칭 키 암호화 방식과 공개 키 암호화 방식

- 암호화 알고리즘
 - 키와 원문 데이터에 수학적 연산 과정을 거치면 암호문이 생성
 - 암호문을 수신자 측에서 복호화하면 원문 메시지를 복원
- 암호화 방법
 - 대칭 키 암호화
 - 비대칭 키 암호화(공개 키 암호화)

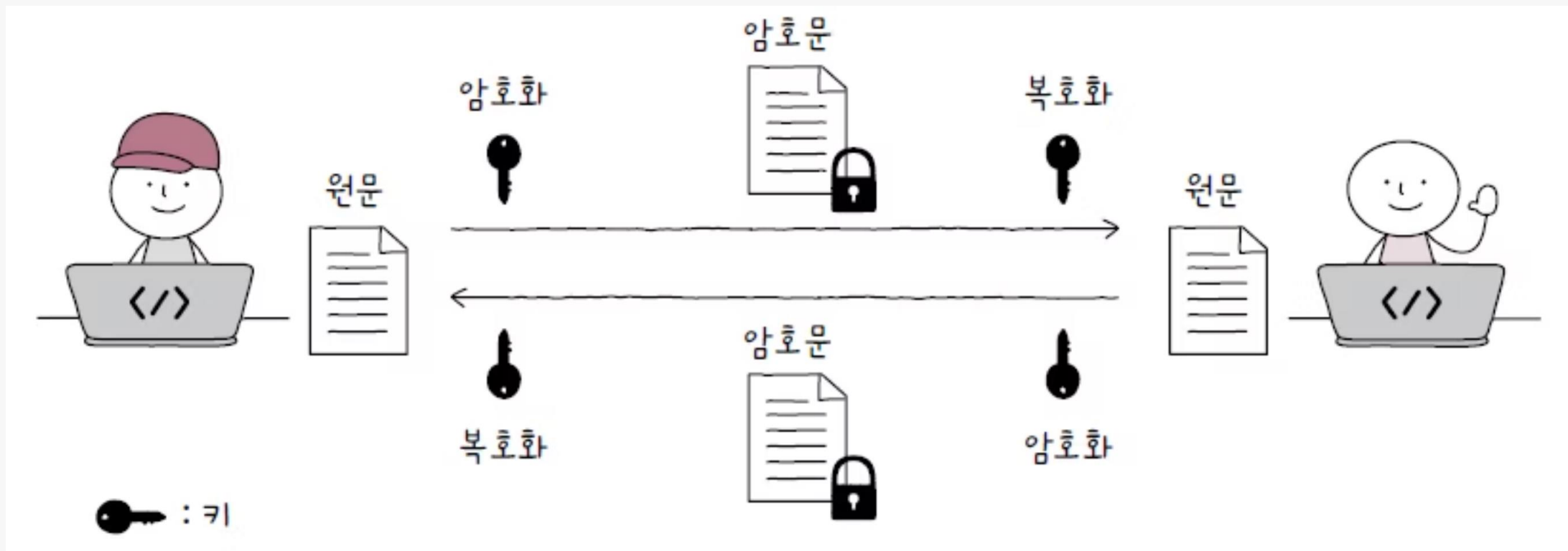


안전성을 위한 기술(3)

- 대칭 키 암호화(symmetric key cryptography)
- 암호화와 복호화에 동일한 키를 사용

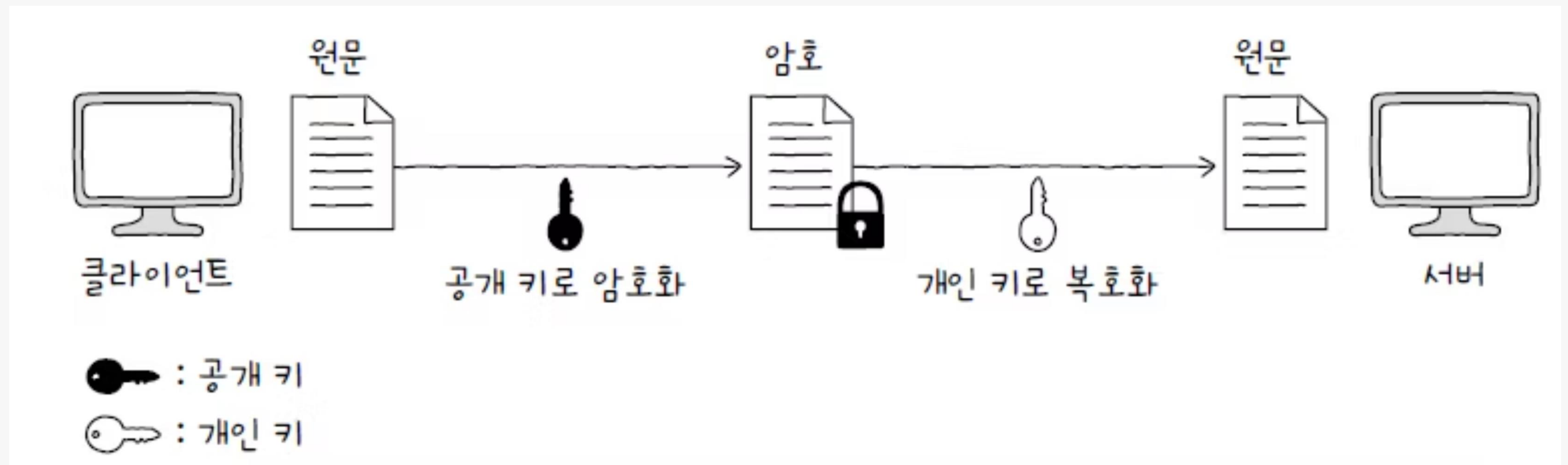
[문제점]

- 상대방에게 안전하게 키를 전달하기 가 어려움
- 동일한 키를 사용하므로 키가 유출되면 큰 문제가 발생

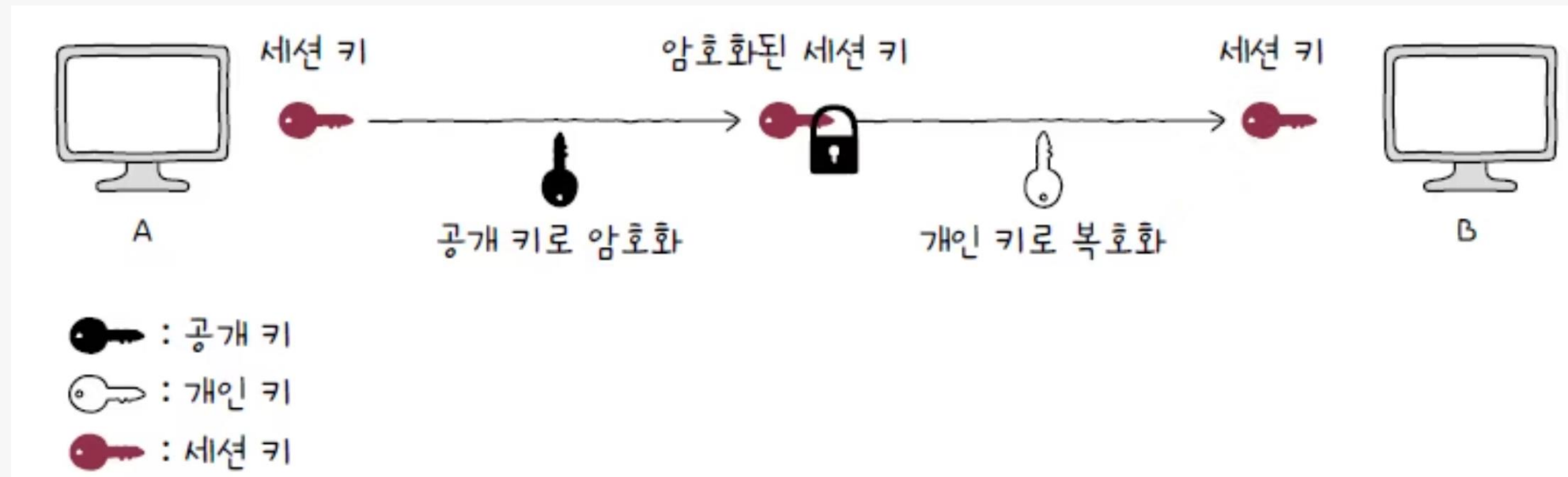


안전성을 위한 기술(4)

- 공개 키 암호화(public key cryptography) 또는 비대칭 키 암호화
- 암호화를 위한 키와 복호화를 위한 키가 다름
- 각각 공개 키(public key)와 개인 키(private key)



안전성을 위한 기술(5)



- 세션 키(session key)
- 대칭 키 암호화
 - (단점) 키를 안전하게 전송하기 어려움 / (장점) 적은 부하 덕분에 암호화 및 복호화를 빠르게 수행
- 공개 키 암호화
 - (단점) 암호화 및 복호화에 시간과 부하가 상대적으로 많이 소요 / (장점) 키를 안전하게 공유
- 세션 키(session key)
 - 장단점을 고려해 대칭 키 암호화 방식과 공개 키 암호화 방식을 함께 사용
 - 대칭 키를 상대방에게 안전하게 전달하기 위해 공개 키로 대칭 키를 암호화
 - 개인 키로 암호화된 대칭 키를 복호화

안전성을 위한 기술(6)

인증서와 디지털 서명

- 공개 키 인증서(public key certificate)
 - 공개 키와 공개 키의 유효성을 입증하기 위한 전자 문서
- 인증 기관(CA, Certification Authority)
 - 인증서의 발급, 검증, 저장과 같은 역할을 수행할 수 있는 공인 기관
- 대표적인 인증 기관
 - IdenTrust
 - DigiCert
 - GlobalSign 등



***.www.naver.com**
발급자: DigiCert SHA2 Secure Server CA
사용 만료: 2022년 6월 8일 수요일 오후 9시 0분 0초 대한민국 표준시
● 인증서가 유효함

이 인증서 사용 시: 시스템 초기 설정 사용 ?

X.509 기본 정책 지정된 값이 아님

제목 이름
국가 또는 지역
주/도
소재지
조직
일반 이름

발급자 이름
국가 또는 지역
조직
일반 이름

일련 번호
버전
서명 알고리즘
매개변수

다음 전에 유효하지 않음 2020년 5월 30일 토요일 오전 9시 0분 0초 대한민국 표준시
다음 후에 유효하지 않음 2022년 6월 8일 수요일 오후 9시 0분 0초 대한민국 표준시

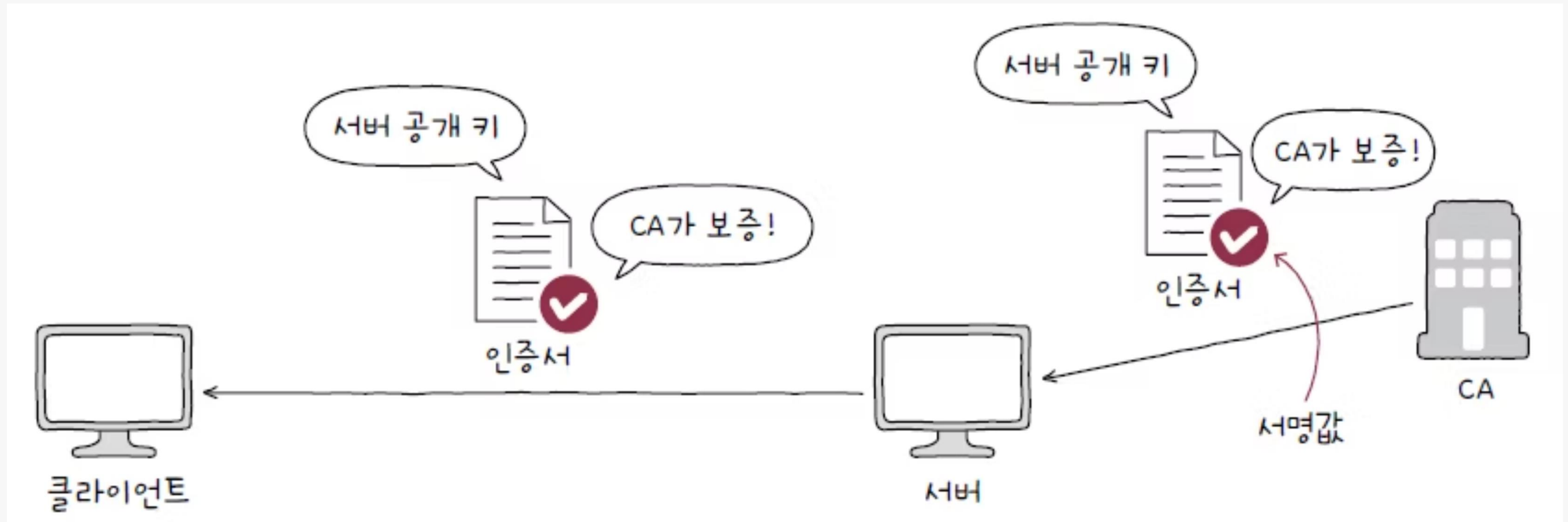
공개 키 정보

알고리즘 RSA 암호화(1.2.840.113549.1.1.1)
매개변수 없음
공개 키 256바이트 : DB 54 BE 14 9B 3C 13 A7 ...
지수 65537
키 크기 2,048비트
키 사용 암호화, 확인, 캡슐화, 유도

서명 256바이트 : 52 CD 2D 09 69 EB 10 56 ...

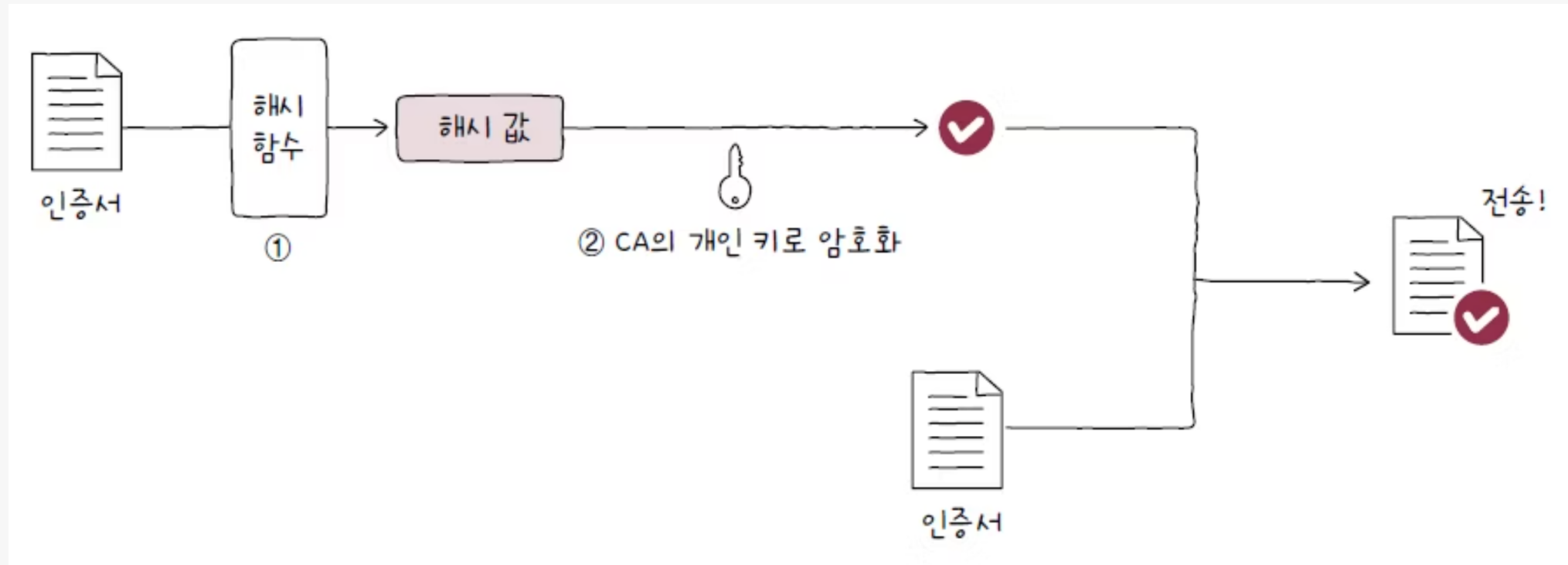
안전성을 위한 기술(7)

- 서명 값(signature)
- 클라이언트는 CA가 발급한 인증서의 서명 값을 바탕으로 인증서를 검증



안전성을 위한 기술(8)

- 서명 값 생성과 전송
 1. 인증서 내용에 대한 해시 값을
 2. CA의 개인 키로 암호화하는 방식으로 생성
- CA는 이렇게 얻어낸 정보를 서명 값으로 삼아 클라이언트에게 인증서와 함께 전송



[Note]

- ①의 결과인 '인증서 내용에 대한 해시 값'을 지문(fingerprint)이라 함

안전성을 위한 기술(9)

❗ 해시 값이란?

- 해시 값 - 해시 함수를 적용시킨 결과값
- 해시 함수 - '임의의 길이의 데이터를 고정된 길이의 데이터로 변환해 주는 함수'
 - 이 함수를 적용시키면 일정한 길이의 데이터가 생성
- 대표적인 해시 함수
 - MD5, SHA-1, SHA-2(SHA-256, SHA-384, SHA-512) 등
- 해시 함수의 특징 - 입력 데이터가 조금만 달라져도 완전히 다른 결과가 나옴
- 해시 함수와 그에 따른 해시 값은 입력값의 변화에 매우 민감하므로 주로 데이터 변조 여부를 검사하는 데 사용
- 어떤 데이터를 송신할 때 '보내고자 하는 데이터'와 더불어 '그 데이터에 대해 특정 해시 함수를 적용시킨 해시 값'을 같이 전송
 - 수신자가 전달받은 데이터에 대한 해시 값을 직접 계산한 뒤, 계산 결과를 전달받은 해시 값과 비교했을 때 같은 값이 도출된다면 데이터 전송 도중 변조되거나 소실되지 않았다고 판단

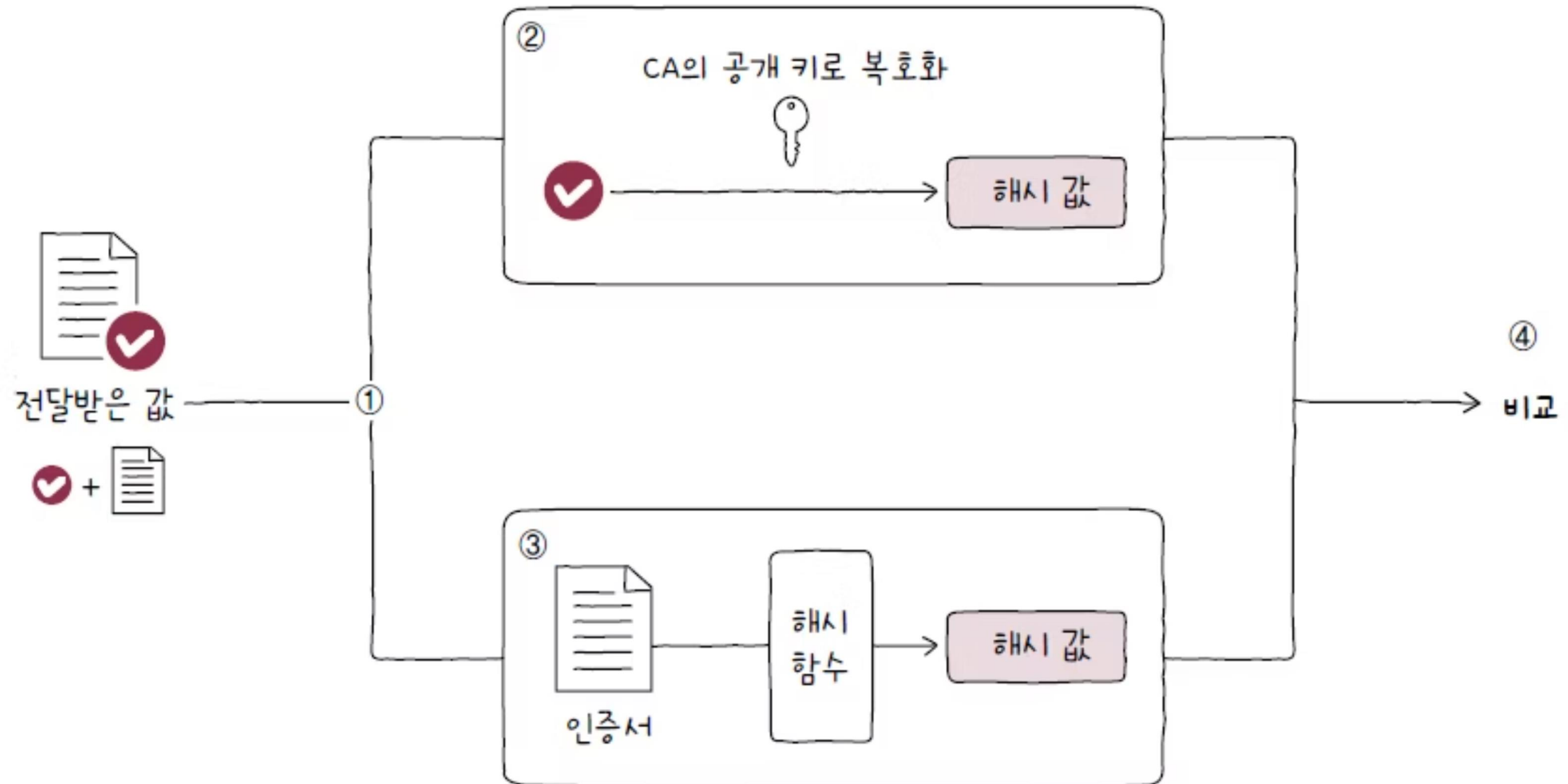
안전성을 위한 기술(10)

- 디지털 서명(digital signature)

– 인증서 검증 과정

- 서명 값과 인증서를 분리(그림 속 ①)
- 서명 값을 CA의 공개 키로 복호화하여 '인증서 내용에 대한 해시 값'을 얻음(그림 속 ②)
- 인증서 데이터에 대한 해시 값을 직접 계산(그림 속 ③)
- 이를 복호화한 값과 비교(그림 속 ④)
- 만일 값이 일치한다면 전달받은 인증서는 확실히 CA의 개인 키로 만들어졌다고 보장

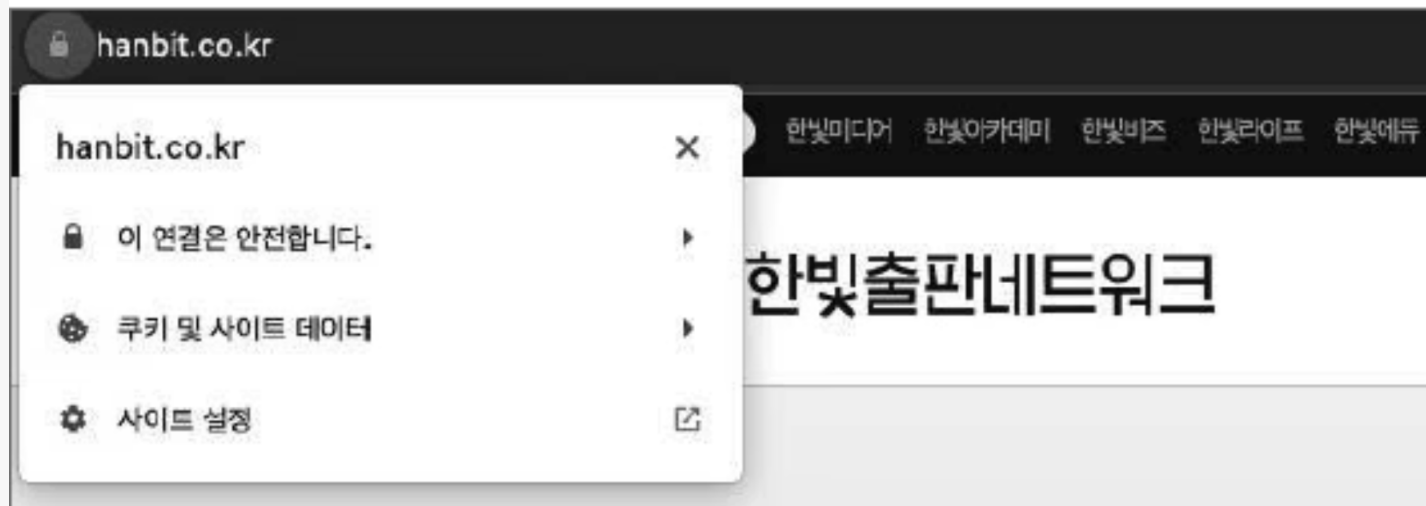
안전성을 위한 기술(11)



안전성을 위한 기술(12)

HTTPS: SSL과 TLS

- SSL(Secure Sockets Layer)과 TLS(Transport Layer Security) 인증과 암호화를 수행하는 프로토콜
 - TLS는 SSL을 계승한 프로토콜
 - 초기 SSL 2.0과 SSL 3.0을 거쳐 TLS 1.0, TLS 1.1, TLS 1.2, TLS 1.3이 순차적으로 출시
 - 따라서 SSL과 TLS의 작동 과정은 세부적인 차이가 있을 수 있으나 큰 틀에서 보면 유사함
- HTTPS(HTTP over TLS)
 - SSL/TLS를 사용하는 대표적인 프로토콜, 공개키, 비밀키 기반 암호화
 - HTTPS는 HTTP 메시지의 안전한 송수신을 위해 개발된 프로토콜



Port: 443

속도: HTTP > HTTPS

중간 변조 불가능, 네트워크 상에서 열람 수정 불가능
서버 측: 인증서 유지 비용 추가, HTTP보다 트래픽 발생 많음

자물쇠 모양의 아이콘은 해당 사이트가 HTTPS를 사용한다는 의미

안전성을 위한 기술(13)

HTTPS 메시지의 송수신 단계

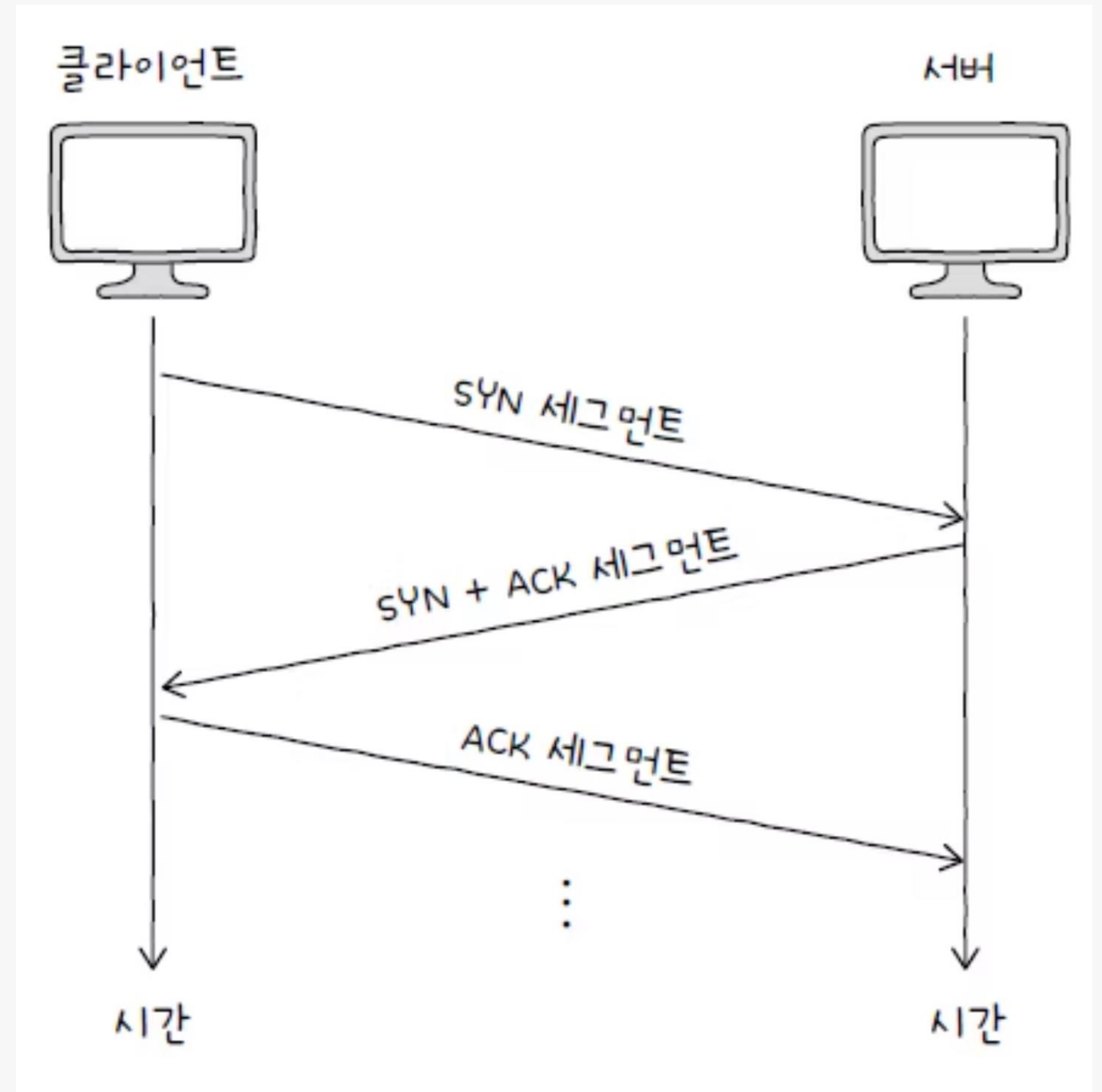
(주로 사용되는 TLS 1.3을 기반으로) 크게 다음과 같은 단계를 거쳐 송수신됩니다.

1. TCP 쓰리 웨이 핸드셰이크
2. TLS 핸드셰이크
3. 암호화된 메시지 송수신

안전성을 위한 기술(14)

① TCP 쓰리 웨이 핸드셰이크

- TCP 연결을 수립하기 위해 두 호스트가 각각 SYN, SYN+ACK, ACK 플래그가 설정된 TCP 세그먼트를 주고받음

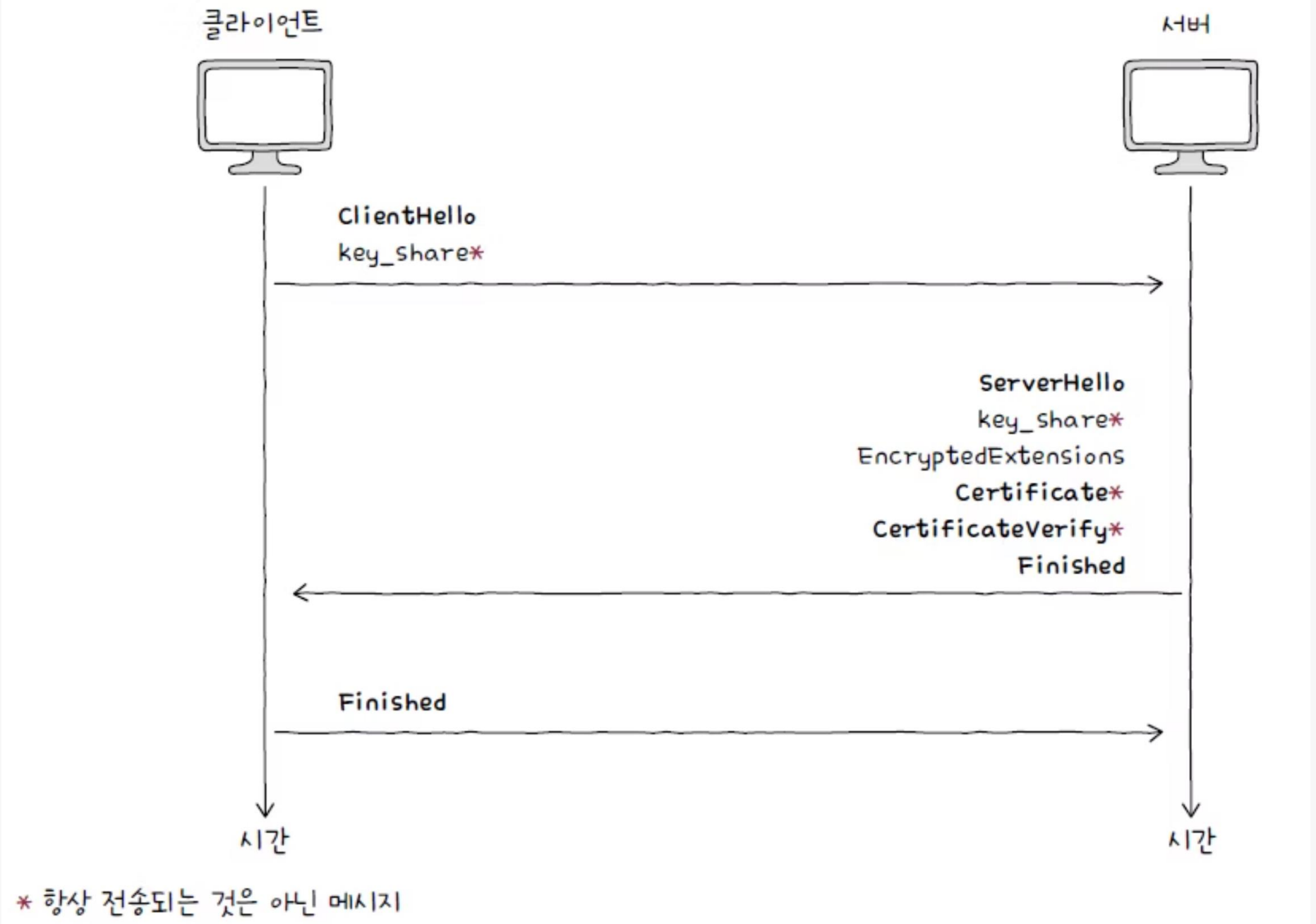


안전성을 위한 기술(15)

② TLS 핸드셰이크

- 암호화 통신을 위한 키를 교환 / 인증서 송수신과 검증
- TLS 핸드셰이크에서의 키 교환
 - 클라이언트는 ClientHello 메시지를 보냄
 - 암호화된 통신을 위해 서로 맞춰 봐야 할 정보들을 제시하는 메시지
 - 지원되는 TLS 버전, 사용 가능한 암호화 방식과 해시 함수, 키를 만들기 위해 사용할 클라이언트의 난수 등이 포함
 - 서버는 ClientHello 메시지에 대한 응답으로 ServerHello 메시지를 전송
 - ServerHello 메시지는 제시된 정보들을 선택하는 메시지
 - 선택된 TLS 버전, 암호 스위트 등의 정보, 키를 만들기 위해 사용할 서버의 난수 등이 포함
 - ClientHello 메시지와 ServerHello 메시지를 주고받으면 암호화된 통신을 위해 사전 협의해야 할 정보들이 결정
 - 결정된 정보를 토대로 서버와 클라이언트는 암호화에 사용할 키를 생성

안전성을 위한 기술(16)



안전성을 위한 기술(17)

- 암호 스위트(cipher suite)
 - '사용 가능한 암호화 방식과 해시 함수'를 담은 정보

The diagram illustrates the structure of TLS cipher suite strings. Two curved arrows point from the annotations to the strings. The first arrow, labeled '암호화 알고리즘' (Encryption Algorithm), points to the middle part of the strings (AES, CHACHA20, or GCM). The second arrow, labeled '해시 함수' (Hash Function), points to the end of the strings (SHA256 or SHA384).

암호화 알고리즘

해시 함수

TLS_AES_128_GCM_SHA256

TLS_AES_256_GCM_SHA384

TLS_CHACHA20_POLY1305_SHA256

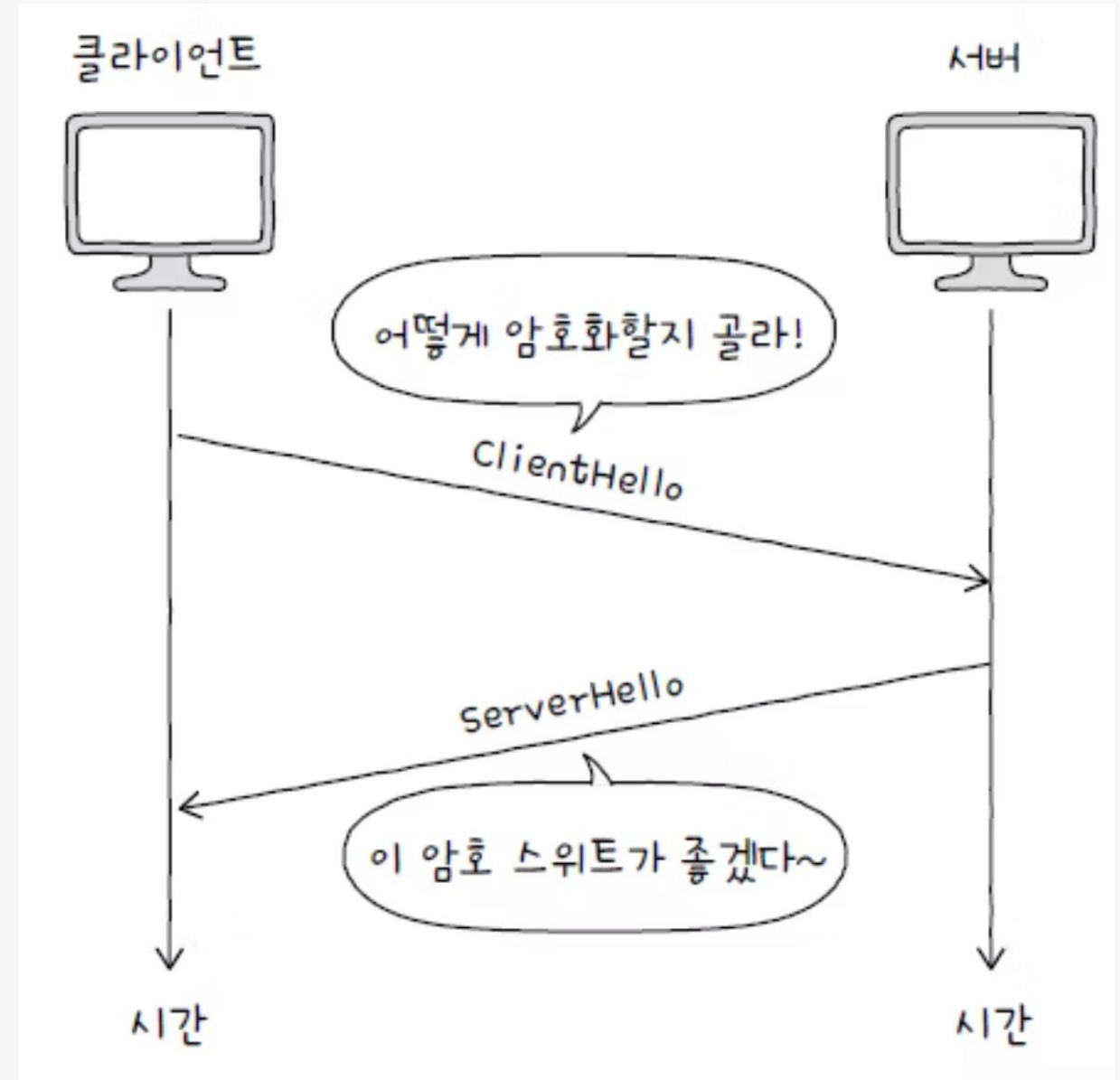
TLS_AES_128_CCM_SHA256

TLS_AES_128_CCM_8_SHA256

안전성을 위한 기술(18)

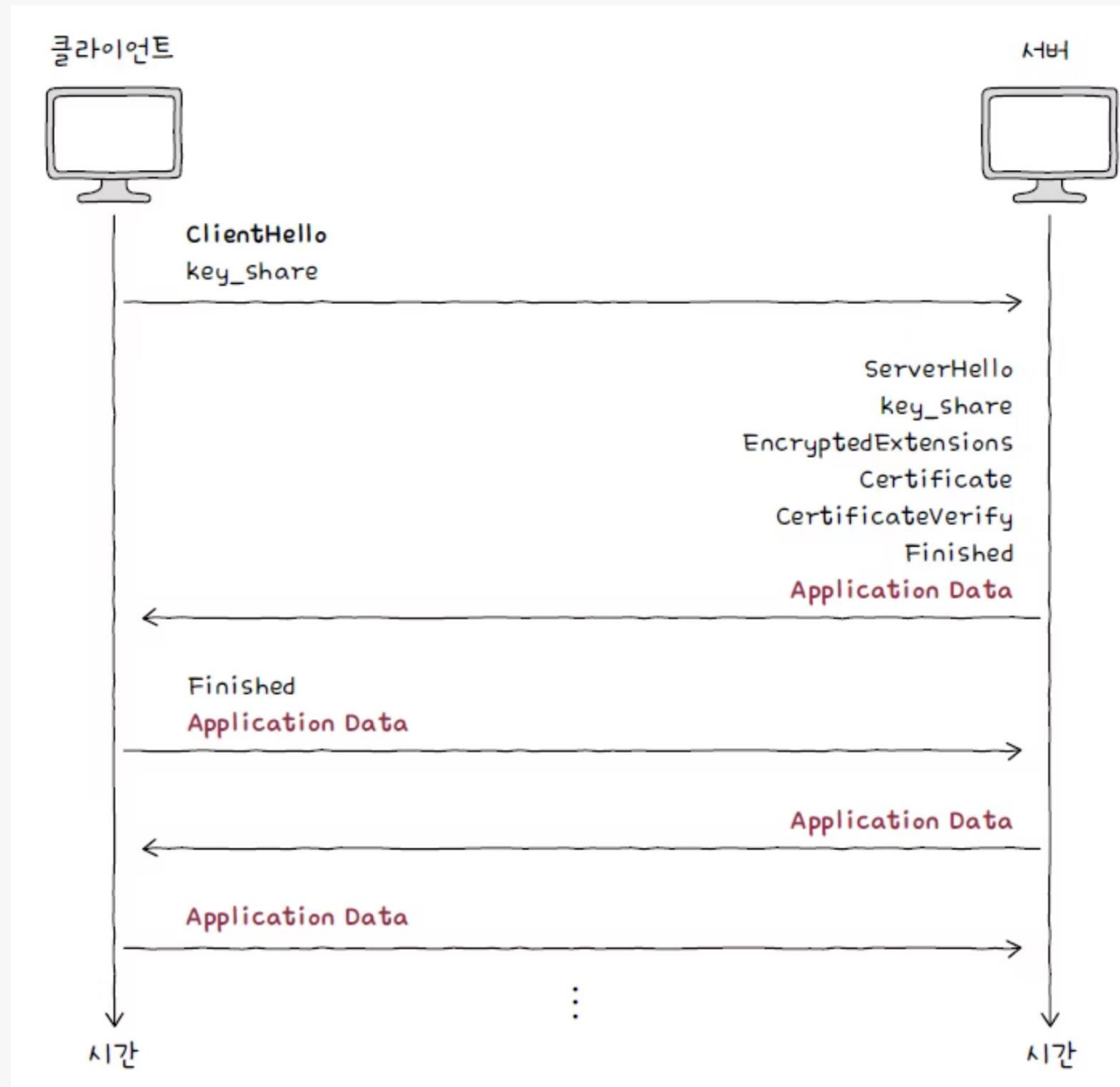
③ 암호화된 메시지 송수신

- 서버는 Certificate 메시지와 CertificateVerify 메시지를 전송
 - 각각 인증서와 검증을 위한 디지털 서명
- 클라이언트는 이 메시지를 토대로 서버의 공개 키를 검증
- 서버와 클라이언트는 TLS 핸드셰이크의 마지막을 의미하는 Finished 메시지를 주고 받음



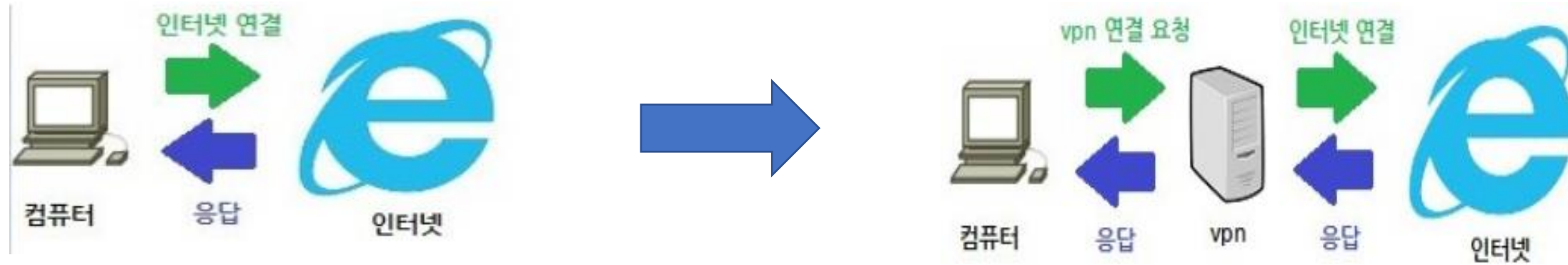
안전성을 위한 기술(19)

(TLS 1.3) Finished 메시지와 함께
암호화된 메시지(Application Data)를 전송



* DTLS (Datagram TLS) DTLS 1.2: TLS 1.2 기반

안전성을 위한 기술(20)



HTTP over VPN:

느린 속도: VPN을 경유하여 인터넷을 사용

- (1) 내 컴퓨터에서 인터넷에 요청할 정보를 암호화하여 VPN에 보냅니다.
- (2) VPN에서는 전달받은 내용을 복호화 하여 인터넷에 정보를 보냅니다.
- (3) 인터넷에서의 결과를 VPN에 전달합니다.
- (4) VPN에서 정보를 암호화하여 내 컴퓨터에 전달합니다.

- 익명성 보장: 인터넷 서버에게 원 사용자는 숨길 수 있다.
- VPN 서버는 내 정보를 모두 알 수 있다.
- 패스워드 읽힐 수 있음,
- 자동 로그인 사이트는 쿠키 통해 로그인 탈취 가능, 보안 사이트 접근도 읽힐 수 있음